

Chapitre 5 : Exercices d'applications

Gérer les accès, les privilèges et sécuriser les communications

MOHAMMED Fahad
BTS SIO 1^{er} année – 2025-2026

Exercice 2 – Gérer les accès et les privilèges

Situation

M. Rens est le président d'une association de réinsertion qui met à la disposition des bénéficiaires un parc de dix postes informatiques pour des tâches bureautiques liées à leur recherche d'emploi. Il souhaite mettre en œuvre une politique de sécurité des données.

Question 1 – Bonnes pratiques d'authentification et d'accréditation (Annexes 1 et 2)

Constats issus des annexes

- La salle dispose de dix postes ; chaque utilisateur se connecte avec des identifiants fournis par le formateur.
- Les comptes sont nommés participant-x (x = numéro du poste) et sont membres à la fois du groupe Administrateurs et du groupe Utilisateurs.
- Le mot de passe et l'identifiant étaient jusqu'alors identiques, ce qui constitue une faiblesse majeure.

Recommandations à formuler à M. Rens

Bonne pratique	Justification
Différencier systématiquement l'identifiant du mot de passe	Un identifiant = participant-1 est public par nature. Si le mot de passe est identique, n'importe qui connaissant le nom du compte peut se connecter.
Utiliser un mot de passe robuste (8 caractères minimum, majuscules, chiffres, caractères spéciaux)	Réduit considérablement le risque d'attaque par force brute ou par dictionnaire.
Ne jamais communiquer son mot de passe à un tiers	Le mot de passe est strictement personnel : le partager annule toute traçabilité des actions.
Renouveler les mots de passe régulièrement (tous les 3 à 6 mois)	Limite l'exposition en cas de compromission non détectée.
Ne pas réutiliser un mot de passe déjà utilisé	Évite qu'une compromission passée permette un accès futur.
Retirer les comptes participants du groupe Administrateurs	Un simple bénéficiaire n'a aucune raison d'avoir des droits d'administration. Ce paramétrage viole le principe du moindre privilège.

Bonne pratique	Justification
Appliquer le principe du moindre privilège	Chaque utilisateur ne doit disposer que des droits strictement nécessaires à l'accomplissement de ses tâches.

Question 2 – Précautions concernant le compte administrateur

M. Rens étant l'administrateur des machines, il doit adopter les précautions suivantes :

- Ne pas utiliser le compte administrateur pour les tâches courantes (navigation Internet, traitement de texte, etc.) : le compte admin ne doit être activé que pour les opérations de maintenance ou de configuration.
- Créer un compte utilisateur standard distinct pour les usages quotidiens, afin de réduire la surface d'attaque en cas de compromission.
- Protéger le compte administrateur par un mot de passe fort, différent de tous les autres comptes, et ne jamais le divulguer aux participants.
- Renommer le compte administrateur intégré (ou le désactiver et en créer un nouveau) afin de rendre plus difficile son identification par un attaquant.
- Ne jamais laisser une session administrateur ouverte sans surveillance, et verrouiller systématiquement le poste lors d'une absence.
- Journaliser les actions effectuées sous le compte administrateur pour conserver une traçabilité des modifications système.

Question 3 – Privilèges à accorder à chaque utilisateur (Annexe 3)

L'annexe 3 montre que le groupe « Tout le monde » dispose actuellement du Contrôle total sur le dossier partagé Formations, ce qui est problématique : n'importe quel participant peut supprimer ou modifier les fichiers déposés par le formateur. La configuration doit être revue conformément au tableau ci-dessous.

Profil / Groupe	Autorisations de partage	Autorisations NTFS
M. Rens (Formateur - Administrateur)	Contrôle total	Contrôle total : création, modification, suppression, gestion des permissions.
Participants (groupe Utilisateurs)	Lecture	Lecture + exécution : consultation des fichiers déposés par le formateur. Écriture autorisée uniquement dans leur propre sous-dossier personnel.
Système	—	Contrôle total (nécessaire au fonctionnement de Windows).
Tout le monde	À supprimer ou limiter à Lecture seule	Supprimer l'autorisation Modification et Contrôle total pour ce groupe. Conserver la Lecture si nécessaire.

En résumé : les participants doivent avoir le droit de lire les fichiers du formateur et d'écrire dans leur propre espace, mais ne doivent en aucun cas pouvoir modifier ou supprimer les fichiers des autres.

Question 4 – Obligations liées au stockage de données à caractère personnel (Annexe 4)

L'annexe 4 présente un cycle de quatre obligations issues du Règlement Général sur la Protection des Données (RGPD). Pour M. Rens, ces obligations se déclinent comme suit :

Obligation (issue de l'annexe 4)	En quoi elle consiste
Établir une politique de protection des données	Définir par écrit les règles applicables au traitement des données personnelles des bénéficiaires (finalités, durée de conservation, personnes habilitées à y accéder). Cette politique doit être connue de tous les intervenants.
Mettre en œuvre des mécanismes et procédures internes permettant la mise en conformité	Déployer des mesures techniques (chiffrement, gestion des droits d'accès, sauvegardes sécurisées) et organisationnelles (procédures en cas de violation de données, gestion des demandes d'exercice des droits des personnes concernées).
Se responsabiliser (plus de déclarations à faire)	Depuis le RGPD (2018), les organismes n'ont plus l'obligation de déclarer leurs traitements à la CNIL. En contrepartie, ils doivent être en mesure de prouver à tout moment leur conformité (principe d'accountability). M. Rens est donc responsable de la protection des données traitées par l'association.
Documenter ses processus	Tenir un registre des traitements recensant l'ensemble des traitements de données personnelles effectués (CV stockés, lettres de motivation, etc.) : nature des données, finalité, base juridique, durée de conservation, mesures de sécurité. Ce registre doit être tenu à jour et présentable lors d'un contrôle CNIL.
Être capable de démontrer le respect des règles	Conserver des preuves concrètes de conformité : politiques signées, journaux d'accès, contrats avec les sous-traitants éventuels, attestations de formation. Cette capacité probatoire est l'essence même du principe d'accountability.

Exercice 3 – Sécuriser les communications

Situation

La salle d'accueil où M. Rens reçoit les bénéficiaires est reliée au même réseau que les services internes de l'association (Direction, Secrétariat-Accueil, Comptabilité). L'association ne dispose pas de budget pour acquérir du matériel supplémentaire. L'objectif est de séparer logiquement ces deux zones sans modifier l'infrastructure physique.

Question 1 – Solution disponible pour segmenter le réseau

La solution à mettre en œuvre sans ajout de matériel est la création de VLAN (Virtual Local Area Network – Réseau Local Virtuel).

- Un VLAN est une segmentation logique du réseau réalisée directement sur le commutateur (switch) existant, sans nécessiter de switch supplémentaire.
- Chaque VLAN constitue un domaine de diffusion indépendant : les postes de la salle d'accueil ne peuvent plus communiquer directement avec les postes du service administratif.
- La communication entre VLANs distincts nécessite un routage (inter-VLAN routing), qui peut être assuré par le routeur-box si celui-ci supporte le protocole 802.1Q.

Question 2 – Procédure de réalisation de la segmentation

Ét a p e	Action à réaliser	Détail / Remarque
1	Identifier les segments réseau à créer	VLAN 10 – Administration (Direction, Secrétariat, Comptabilité) ; VLAN 20 – Salle Accueil (10 postes participants)
2	Accéder à l'interface de configuration du commutateur	Via console (port série) ou interface web selon le modèle du switch
3	Créer les VLAN sur le commutateur	Commandes : vlan 10 / name Administration, puis vlan 20 / name SalleAccueil
4	Affecter chaque port du switch au VLAN correspondant	Ports des postes Direction, Secrétariat, Comptabilité → VLAN 10 ; ports des 10 postes salle accueil → VLAN 20 (mode access)
5	Configurer le port de liaison avec la Box en mode trunk (802.1Q)	Ce port doit transporter les trames des deux VLANs simultanément vers le routeur
6	Vérifier la configuration des VLAN sur le commutateur	Commande : show vlan brief – chaque port doit apparaître dans le bon VLAN
7	Tester l'isolation	Un ping entre un poste VLAN 10 et un poste VLAN 20 doit échouer (isolation correcte) ; un ping à l'intérieur d'un même VLAN doit réussir
8	Tester l'accès Internet depuis les deux VLAN	Si le routeur supporte le routage inter-VLAN (802.1Q), les deux zones doivent conserver un accès Internet

7. Tester l'isolation

Depuis Direction, ping vers PC-Accueil-1

```
C:\>ping 192.168.1.100

Pinging 192.168.1.100 with 32 bytes of data:

Request timed out.

Ping statistics for 192.168.1.100:
    Packets: Sent = 2, Received = 0, Lost = 2 (100% loss),

Control-C
^C
C:\>|
```

Depuis Direction, ping vers Secrétariat

```
C:\>ping 192.168.1.10

Pinging 192.168.1.10 with 32 bytes of data:

Reply from 192.168.1.10: bytes=32 time=4ms TTL=128
Reply from 192.168.1.10: bytes=32 time<1ms TTL=128
Reply from 192.168.1.10: bytes=32 time<1ms TTL=128
Reply from 192.168.1.10: bytes=32 time<1ms TTL=128

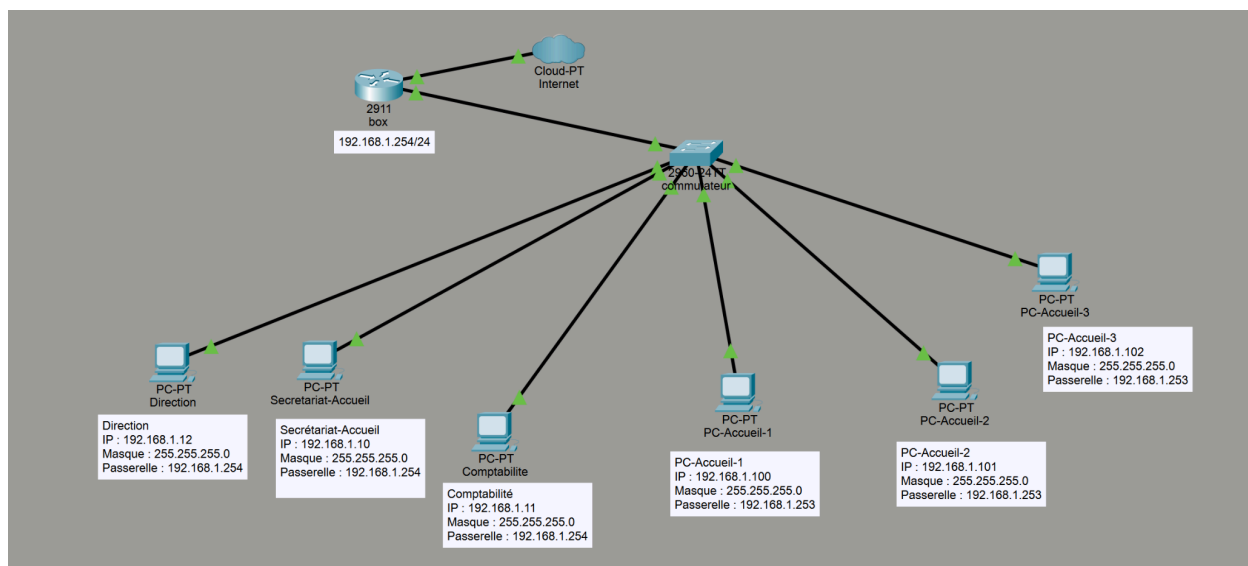
Ping statistics for 192.168.1.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 4ms, Average = 1ms
```


Question 3 – Simulation Packet Tracer

La simulation a été réalisée sous Packet Tracer en reproduisant l'infrastructure présentée dans l'annexe et en appliquant la segmentation VLAN sur le commutateur. Les éléments configurés sont décrits ci-dessous.

Topologie reproduite

- Box (192.168.1.254 /24) connectée au port trunk du commutateur.
- Commutateur configuré avec deux VLAN :
 - VLAN 10 (Administration) : Direction 192.168.1.12/24, Secrétariat-Accueil 192.168.1.10/24, Comptabilité 192.168.1.11/24.
 - VLAN 20 (Salle Accueil) : 10 postes participants, adresses 192.168.1.100 à 192.168.1.110 /24.



show vlan brief dans le CLI switch

VLAN	Name	Status	Ports
1	default	active	Fa0/7, Fa0/8, Fa0/9, Fa0/10 Fa0/11, Fa0/12, Fa0/13, Fa0/14 Fa0/15, Fa0/16, Fa0/17, Fa0/18 Fa0/19, Fa0/20, Fa0/21, Fa0/22 Fa0/23, Fa0/24, Gig0/2
10	Administration	active	Fa0/1, Fa0/2, Fa0/3
20	SalleAccueil	active	Fa0/4, Fa0/5, Fa0/6
1002	fddi-default	active	
1003	token-ring-default	active	
1004	fddinet-default	active	
1005	trnet-default	active	

Switch#

Question 4 – Conséquences de la segmentation logique sur le routeur box (interface LAN)

La mise en place de VLAN sur le commutateur a une conséquence directe sur l'interface physique LAN de la box :

- Avant la segmentation, la box ne voit qu'un seul réseau plat (192.168.1.0/24) sur son interface LAN : une seule interface physique, un seul domaine de diffusion.
- Après la segmentation, le port de la box relié au switch reçoit des trames de deux VLAN distincts. Pour que la box puisse router le trafic de chaque VLAN vers Internet, son interface LAN doit être configurée en mode trunk 802.1Q et prendre en charge des sous-interfaces (ou interfaces virtuelles) :
 - Sous-interface pour le VLAN 10 (Administration), avec sa passerelle.
 - Sous-interface pour le VLAN 20 (Salle Accueil), avec sa passerelle.
- Si la box grand public utilisée ne supporte pas le mode trunk 802.1Q, elle ne pourra pas router les trames vlan-tagguées et les postes de la salle accueil perdront l'accès Internet. Dans ce cas, il sera nécessaire soit de remplacer la box par un routeur compatible, soit de mettre en place un routeur logiciel (router-on-a-stick) sur un poste existant.
- En résumé : la segmentation VLAN isole logiquement les deux zones au niveau du switch, mais l'accès Internet multizone impose que le routeur box prenne en charge le tagging 802.1Q sur son interface LAN physique.